Device-Fingerprint Capture — One-Pager for DPO Review

> **Revised 2026-10-22.** The capture was measured collecting in production on 2026-08-17 (9 rows / 4 accounts; disclosed on `/privacy` §"Device identifier"). In code it is behind `NEXT_PUBLIC_DEVICE_FINGERPRINT_ENABLED` and the `device_fingerprint` control — a code default is not the production value; check `/admin/data-privacy`. The server salt is fixed (`DEVICE_HASH_SALT`), which clustering needs. Owner as DPO (2026-09-16): hashes deleted on account close, excluded from export, pruned on a schedule — the 24-month prune promised on `/privacy` has **no job in code yet**. The "vendors are charged per lead" premise below is outdated (answering is free); the basis is review/rating integrity (finding #19 of 2026-08-24). LIA + DPO sign-off: task `t2-10`. DPO contact: dpo@setnayan.com.

> **For:** the Setnayan DPO (the owner, Indalecio S. Casasola II — per `[[dpo-designation-owner]]`), NPC-registered.
> **Ask:** review + sign off on the legal basis, notice wording, and retention below before the **device-fingerprint capture** (fake-inquiry protection · Phase E) is switched on. The design is deliberately minimal and privacy-preserving — this should be a **sign-off, not a redesign**.
> **Date:** 2026-07-12. **Law:** RA 10173 (Data Privacy Act) + NPC issuances.
> **Companion:** `Vendor_Fake_Inquiry_Protection_Build_Plan_2026-07-11.md` (Phase E), `Data_Retention_Schedule_2026-07-11.md` (new class 10).

What we want to do

To catch **sock-puppet fraud** — one bad actor (often a competing vendor) spinning up many fake couple accounts to spam a vendor's inbox or drain the token a vendor spends to answer — we need to tell when several "different" accounts are really **the same browser/device**. So, on a **secured (logged-in) account**, we record a **coarse, first-party device identifier**:

- A **random id** generated once in the browser's `localStorage` (like a cookie). It is **NOT** a behavioral/biometric fingerprint — no canvas/font/WebGL probing, no third-party fingerprinting SDK, no cross-site tracking.
- Sent to our own server, where it is **hashed** (`SHA-256` with a server-side salt) and stored as `user_devices.device_hash` against the account. **The raw id is never stored** — only the one-way hash.
- Two accounts that share a device produce the **same hash**, which lets our existing fraud-clustering flag them for **human review** (it never auto-bans anyone).

Nothing here is shared with any third party, used for advertising, or used to profile a couple's planning behavior.

The legal basis we're relying on

- **Legitimate interests (RA 10173 §12(f))** — preventing fraud and protecting the integrity of the marketplace (and the vendors who pay us) is a textbook legitimate-interest processing purpose. The data is a **pseudonymous hash**, the least-intrusive signal that achieves the purpose, and it is **not sensitive personal information**.
- Balancing test: the intrusion is minimal (a hashed random id, fraud-only, no tracking), the interest is substantial (vendors are charged per lead; fakes are a direct financial harm), and it is disclosed. We assess legitimate interest as the correct basis rather than consent — **but this is the DPO's call** (see item 1 below).

The seven safeguards built into the design

1. **Coarse by design.** A random localStorage id — explicitly **not** a canvas/font behavioral fingerprint and **no external SDK**. It identifies a *browser*, not a *person's* behavior.

2. **Hashed, raw value never stored.** `SHA-256(salt + id)` server-side; the DB holds only the hash. The salt is a server secret.

3. **Purpose limitation.** Used **only** for fraud detection (identity-cluster review). Never for ads, marketing, personalization, or sold.

4. **Secured accounts only.** Anonymous/draft sessions are not captured — no fraud-subject identity, no capture.

5. **Data minimization + first-party only.** One hash per (account, device) + a `last_seen_at`. No IPs stored for this (IP is explicitly out of scope of the cluster signals). No third-party recipients.

6. **Retention clock.** New **class 10** in the retention schedule: kept for fraud-prevention while the account is active, **purged with the account** (class 5 tail); `last_seen_at` enables a rolling prune of stale device rows. Confirm the period (item 3).

7. **Rights honored.** The device hash is account-linked personal data → included in the existing **"download my data"** export and **deleted on account deletion** (iteration 0025). An opt-out is available if the DPO decides consent (not legitimate interest) is required.

What we'd like the DPO to confirm

1. **Legal basis** — that **legitimate interest (fraud prevention)** is the correct basis, so this can be **on-by-default when enabled** with notice; OR direct us to make it **consent-based** (a Privacy-settings toggle, defaulting off).

2. **Notice wording** — proposed privacy-policy line: *"To keep our marketplace safe, we record a hashed identifier for the device you sign in from and use it only to detect fraud and fake accounts. We don't use it for advertising or tracking you across other sites."* Confirm this is adequate.

3. **Retention period** — confirm class 10 (life-of-account + purge-with-account, with a rolling prune of device rows unused for a set period — propose 24 months).

4. Whether a **Privacy-settings entry** (disclosure + optional opt-out) is required in addition to the policy notice.

Engineering state (so the DPO knows the stakes)

LIVE — collecting in production since 2026-07-12. (!) CORRECTED 2026-08-17: this was described as built-but-switched-off. Measured in production on 2026-08-17: 9 device rows across 4 accounts, first written 2026-07-12, most recent the same day as this correction. The 2026-07-23 instruction to hold it off was SUPERSEDED on 2026-07-24 by the owner-locked Interim Payments & Privacy Deferral Policy, which deliberately activated it; the live public /privacy notice discloses device-fingerprint processing accordingly. Basis relied on: RA 10173 §12(f) legitimate interest (fraud prevention). STILL OWED: the documented legitimate-interest assessment (NPC task t2-10). Collection is coarse and first-party — a random id in localStorage, hashed server-side, raw never stored; no canvas/behavioural fingerprint and no external SDK; secured accounts only.

_(The original text read: "Built but switched OFF behind a flag (`NEXT_PUBLIC_DEVICE_FINGERPRINT_ENABLED`, default OFF) — it cannot collect anything" until the flag is flipped, which we will not do until this sign-off. Fully reversible (flag off → capture stops; existing `user_devices` rows are purgeable). The capture only writes `user_devices`; the fraud-cluster detection it feeds runs in **shadow mode** (admin review only, never auto-action).

Related: `[[dpo-designation-owner]]` · `Data_Retention_Schedule_2026-07-11.md` (class 10) · `Vendor_Fake_Inquiry_Protection_Build_Plan_2026-07-11.md` (Phase E) · `0025_profile_settings/` (export + deletion + Privacy tab) · `Setnayan_AI_Data_Use_DPO_Review_2026-06-29.md` (sibling DPO one-pager).